Seguridad en Sistemas, Aplicaciones y el Big Data

Tema 1. Seguridad en Windows Server

Índice

Esquema

Ideas clave

1.1. Introducción y objetivos

1.2. Seguridad en Windows Server

1.3. Seguridad en Active Directory. Políticas base

1.4. Analizadores de políticas base

1.5. Herramientas de análisis de configuración de seguridad

1.6. Referencias bibliográficas

A fondo

Guías de seguridad de entornos Windows 500 CCN-CERT

Configuraciones de seguridad de entornos Windows NIST

Herramienta CLARA CCN CERT

Security Compliance Toolkit de Microsoft 1.0

Configuración de seguridad Active Directory a través de Group Policy Objects

Test

© Universidad Internacional de La Rioja (UNIR)

1.1. Introducción y objetivos

El propósito de este tema es proporcionar una implementación segura para la instalación de un sistema Windows Server, que actúa como un controlador de dominio (DC) o un servidor miembro de un dominio, siguiendo las instrucciones contenidas aquí, de acuerdo con las guías STIC disponibles en el sitio web del CNI-CCN-CERT.

Las configuraciones aplicadas a lo largo de este tema están diseñadas para ser lo más restrictivas posible, disminuir la superficie de ataque y, por consiguiente, las amenazas y riesgos que puedan existir. Según los casos, dependiendo de la funcionalidad que requiera su servidor, es posible que deba modificar los perfiles que se muestran aquí para permitir que su dispositivo brinde servicios adicionales. Sin embargo, cabe señalar que las áreas de aplicación son diversas y por consiguiente dependen de las aplicaciones, características y capacidades de los servicios suministrados por diferentes organizaciones.

Así, se crean modelos y estándares de seguridad mediante la definición de **principios generales de seguridad** que permitan cumplir en el futuro las condiciones mínimas y obligatorias de dicha seguridad establecidas en el **Esquema Nacional de seguridad (ENS).** Un ambiente clasificado para aplicaciones seguras en un entorno de red sensible y el nivel máximo de seguridad que se puede establecer se basa en los requisitos de las **directrices CCN STIC 301.**

© Universidad Internacional de La Rioja (UNIR)

A continuación, se describe el **proceso de aplicación de seguridad** en un entorno de Windows Server. Este constará de los siguientes pasos:

1	Tener en cuenta que, además de los requisitos que debe cumplir al instalar Windows Server, es posible que deba revisar los requisitos de otros servicios y aplicaciones que se utilizarán en el futuro, especialmente los **requisitos de partición de disco.** Para la mayoría de los servicios y productos es necesario colocar el sistema operativo y el resto de los archivos de la aplicación en diferentes particiones.
2	Si el servidor se configurará como un DC, se deberá actuar de la siguiente forma: ▸ Examinar y seguir el apartado de implementación de seguridad sobre un DC. ▸ Además, es requisito seguir el apartado relativo a la seguridad de Directorio Activo.
3	Si el servidor es un miembro del dominio, se debe actuar de la siguiente manera: ▸ Estudiar e implementar, el apartado relativo a la seguridad del Directorio Activo. ▸ Estudiar y aplicar el apartado relativo a la implementación de seguridad sobre un servidor miembro.

Tabla 1. El proceso de aplicación de seguridad en un entorno de Windows Server. Fuente: elaboración propia.

El propósito de lo visto aquí es servir como un punto de referencia de seguridad que debe adaptarse a las características y necesidades específicas de cada organización. Los procedimientos establecidos asumen que se está configurando el sistema desde un ambiente limpio (formateado) en un ambiente de producción dentro del ENS.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Objetivos

- Conocer las principales características de seguridad de Microsoft Windows Server.
- Aprender cómo implementar la seguridad en un domino mediante Active Directory y políticas de seguridad.
- Conocer los principales analizadores de políticas base y herramientas de análisis de configuración de seguridad.
- Aplicar la guía *CCN-STIC-570A23 ENS incremental Dominio categoría básica* para definir la política de seguridad del dominio.
- Aplicar la guía *CCN-STIC-57023 ENS incremental Controladores de Dominio categoría básica* para establecer la seguridad del servicio DC.
- Aplicar la guía *CCN-STIC-599A23 Seguridad en* los *clientes Windows (cliente miembro de dominio).*

© Universidad Internacional de La Rioja (UNIR)

1.2. Seguridad en Windows Server

Novedades de seguridad

En Windows server 2022 se incorporan las siguientes medidas de seguridad:

- **Secured-core server:** aprovechan al máximo las capacidades del *hardware,* firmware y sistema operativo para protegerlo de las amenazas. La protección habilitada por un servidor Secured-core crea una base sólida para los datos críticos y las aplicaciones que se utilizan en ese servidor.

- **Hardware root-of-trust:** viene con el servidor Secured-core y proporciona almacenamiento seguro para datos confidenciales y claves, como permisos para monitorizar y medir los componentes cargados en el momento del arranque Trusted Platform Module 2.0 (TPM 2.0).

- **Firmware protection:** según informes recientes, las plataformas de malware y ransomware agregan funciones de *software* y aumentan el riesgo de ataques dirigidos a los recursos de firmware corporativos, como los controladores de dominio de Active Directory. El sistema Secured-core aísla la seguridad crítica del hipervisor de dichos ataques con la ayuda de los procesadores compatibles con la tecnología Dynamic Route Measurement Trust (DRTM) y la protección DMA.

- **Virtualization-based security (VBS):** los servidores secured-core incluyen VBS e integridad de código basada en hipervisor (HVCI). VBS y HVCI protegen contra todo tipo de vulnerabilidades que suelen ser foco de los ataques de minería de criptomonedas, debido al aislamiento proporcionado por VBS entre las partes privilegiadas del sistema operativo, como el kernel y el resto del sistema. VBS también ofrece más funciones que los clientes pueden usar, como la protección de credenciales, para mejorar su protección en el dominio.

- **Transport HTTPS and TLS 1.3:** habilitado por defecto en todas las conexiones.

© Universidad Internacional de La Rioja (UNIR)

- **Secure DNS:** Solicitudes de resolución de nombres DNS encriptadas con DNS sobre HTTPS.

- **Server Message Block (SMB):** Windows Server admite conjuntos de cifrado AES256GCM y AES256CCM para cifrado y firma SMB. Windows lo negocia automáticamente cuando se conecta a otra computadora que admita este cifrado más alto. También se lo puede aplicar mediante la política de grupo. Windows Server seguirá admitiendo AES128 para un bajo nivel de compatibilidad.

Novedades de seguridad destacadas en Windows Server 2025

- **Seguridad multicapa *core-to-cloud:*** una filosofía de defensa en profundidad que incluye mejoras desde el *hardware,* firmware, OS hasta redes (Microsoft, s. f.).

- ***Hotpatching* para servidores conectados a Azure Arc:** permite aplicar actualizaciones de seguridad sin necesidad de reiniciar el sistema, lo que reduce el *downtime.* Está en versión *preview* para muchos escenarios y con disponibilidad ampliada (aunque para algunos entornos es de pago) (Microsoft, s. f.).

- **Credential Guard activado por defecto:** protege credenciales sensibles de los procesos de ataque, como *pass-the-hash,* al aislarlas mediante tecnología de virtualización. Solo en dispositivos que cumplan los requisitos (Microsoft, s. f.).

- **Protección de claves criptográficas con VBS *(virtualization-based security):***

  - *VBS enclaves*: ejecución en entornos de memoria aislada para operaciones sensibles, incluso si un atacante obtiene privilegios elevados (Microsoft, s. f.).

  - *VBS key protection*: las claves privadas se aíslan en parte al ser protegidas por TPM, de modo que no pueden extraerse fácilmente de la memoria ni exportarse en texto plano (Microsoft, s. f.).

© Universidad Internacional de La Rioja (UNIR)

- **Mejoras en SMB y transferencia de archivos/compartición:**
  - SMB sobre QUIC: para acceso seguro a archivos a través de Internet sin necesidad de VPN (LaFoute, 2025).
  - SMB *signing* obligatorio por defecto: tanto para conexiones entrantes como salientes para reducir riesgo de ataques, como *man-in-the-middle* y *relay* (NedPyle, 2024).
  - Bloqueo de autenticación por NTLM en ciertos escenarios: para evitar degradaciones inseguras de seguridad (NedPyle, 2024).
  - *Rate limiting* en autenticaciones SMB: para proteger contra ataques de fuerza bruta (Microsoft, s. f.).
- **Active Directory más seguro:**
  - LDAP cifrado por defecto (Hartmann, 2024).
  - Mejoras en Kerberos: algoritmos de cifrado más fuertes (como AES + SHA-256 y SHA-384) y mayor flexibilidad criptográfica (Posey, 2024).
  - Aumento del tamaño de página de base de datos de AD para mayor escalabilidad y rendimiento (Microsoft, s. f.).
  - Protección de atributos confidenciales de directorios que requiere que ciertas acciones se realicen solo sobre canales cifrados (Hartmann, 2024).
  - Bloqueo de métodos antiguos/inseguros para cambios de contraseña remotos (SAM RPC) cuando no se usen protocolos seguros (Hartmann, 2024).
- **Servidores *secure-core/firmware* confiable:** mayor defensa contra ataques a nivel de *firmware* y componentes de *hardware.* Incluye requisitos más estrictos de *hardware/hardware* compatible, validaciones de integridad desde el arranque, etc. (Microsoft, s. f.).

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- **Líneas base de seguridad actualizadas *(security baselines)* y auditoría:**

  - Nuevas configuraciones recomendadas para Windows Server 2025 con controles más estrictos en políticas, cuentas, autenticación, etc. (Munck, 2025).

  - Nuevas políticas de auditoría relacionadas con SMB (clientes que no soportan cifrado, que no soportan firmar, conexiones *guest* inseguras, etc.) (Munck, 2025).

© Universidad Internacional de La Rioja (UNIR)

1.3. Seguridad en Active Directory. Políticas base

Windows Active Directory es un servicio que posibilita que las aplicaciones encuentren, usen y administren los recursos *hardware* y *software* del dominio. Al planificar y diseñar su infraestructura de Active Directory se deben analizar las medidas de seguridad que se le pueden aplicar. Dos cosas son especialmente importantes al implementar estas pautas de configuración: **Unidades organizativas y políticas de dominio agrupadas por GPO.**

Para ayudar a las organizaciones a implementar las medidas de seguridad, la guía de seguridad, de acuerdo con el Esquema Nacional de Seguridad (ENS), ha considerado la necesidad de crear tres alcances de implementación o perfiles basándose en la calificación de la información manejada por los sistemas de información. Esto se ha realizado tomando en consideración lo indicado por la medida «MP.INFO.2 Calificación de la información»:

- Estándar
- Uso oficial.
- Materias clasificadas.

Estos tres alcances englobarán **configuraciones** en función de la categoría de los sistemas de información que se definen bajo el Real Decreto del ENS, siendo estas las siguientes:

- Básica.
- Media.
- Alta.
- Sistemas clasificados.

© Universidad Internacional de La Rioja (UNIR)

		CALIFICACIÓN DE LA INFORMACIÓN/PERFIL		
		ESTÁNDAR	USO OFICIAL	MATERIAS CLASIFICADAS
CATEGORÍA DEL SISTEMA DE INFORMACIÓN	BÁSICA	✓	✗	✗
	MEDIA	✓	✓	✗
	ALTA DIFUSIÓN LIMITADA	✗	✓	✗
	CONFIDENCIAL RESERVADO	✗	✗	✓

Tabla 1. Selección de perfil de medidas de seguridad. Fuente: elaboración propia.

Infraestructura de unidades organizativas

El principal objetivo del diseño de una unidad organizativa (OU) es crear una política de grupo coherente en todos los servidores, lo que permite a los usuarios que residen en el servicio de directorio responder y cumplir con los procedimientos y estándares de seguridad de la organización. Según se especifica en STIC 570A (2018):

> «a) Nivel de Dominio. Para cumplir los requisitos comunes de seguridad, tales como directivas de cuenta y de contraseñas que deben ejecutarse en todos los servidores del dominio.
>
> b) Nivel de Referencia. Para cumplir los requisitos de seguridad específicos del servidor que son comunes a todos los servidores miembros del dominio.
>
> c) Nivel de Rol. Para cumplir los requisitos de seguridad de los roles específicos del servidor. Por ejemplo, los requisitos de seguridad de los servidores de infraestructura son distintos de los de los servidores que ejecutan Internet Information Services (IIS)» (p. 18).

© Universidad Internacional de La Rioja (UNIR)

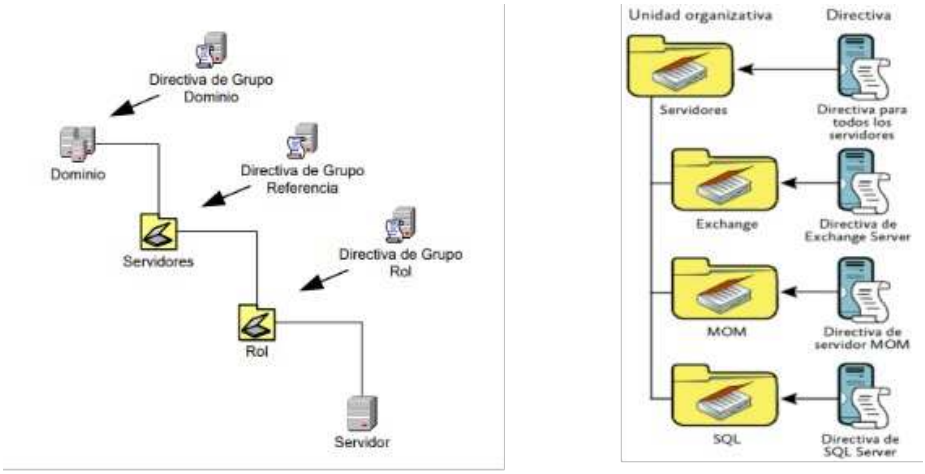


Figura 1. Estructura de Unidades Organizativas. Fuente: adaptado de Centro Criptológico Nacional, 2018; Fran, 2010.

El diseño basado en OUs y directivas/políticas de grupo garantiza que los servidores y máquinas de usuario de la empresa usen de forma coherente la configuración de seguridad estándar. Además, tanto la estructura de OU como la aplicación de la política de grupo deben posibilitar configuraciones de seguridad para servidores concretos en la organización a través de un diseño detallado.

© Universidad Internacional de La Rioja (UNIR)

Primero se configuran OUs para los diferentes roles de servidor, estas están anidadas dentro de las OUs correspondientes a los servidores miembro, sin embargo, los controladores de dominio tienen sus propias OUs. Para ello, primero se debe crear una política de grupo de referencia siendo necesario utilizar la configuración base (modelo-plantilla) de seguridad de referencia «***CCN-STIC-570A23 Incremental servidores***» para cumplir con los requisitos técnicos aplicables establecidos según el perfilado estándar. En el momento de selección de las configuraciones de seguridad, deberá seleccionar aquella acorde a su perfilado (estándar, uso oficial o materias clasificadas) y asociarlo a la política de seguridad, Group Policy Objects (GPO), aplicada en la OU «***Servidores Miembro***». La política de grupo a la que se hace referencia debe incluir la configuración necesaria para cada uno de los servidores de la organización y debe ser lo más restrictiva en todos los parámetros generales.

Los **roles de servidor** que deben diferir de esta política deben incluirse en unidades organizativas de servidor específicas. Siguiendo con lo que se mostró anteriormente, debe crearse otra política de grupo para acomodar gradualmente cada uno de los diferentes roles de servidor que puedan existir en la empresa. Al asignar estos roles desde la OU del servidor miembro a la unidad organizativa de tipo nivel, los cambios son acumulativos, la gestión de la política de seguridad se simplifica y todos los equipos miembros se aplican de forma coherente.

Se pueden seguir varios métodos a la hora de crear una estructura lógica de Active Directory. Sin embargo, se recomienda adoptar este método, ya que será la base utilizada en todos los tutoriales de la colección CCN-STIC 500. En la serie de guías desarrolladas para diferentes productos todos los archivos de plantilla incrementales deben aplicarse a OUs que sean de menor nivel que la de los servidores miembro.

© Universidad Internacional de La Rioja (UNIR)

Por lo tanto, como se vio en el ejemplo, a cada una de estas unidades organizativas de nivel inferior se le debe aplicar el archivo CCN-STIC-570A23 Incremental Servidores (estándar/uso oficial/materias clasificadas).inf y un archivo incremental específico para definir el rol de cada unidad en la organización. Los requisitos de seguridad para cada función/rol de servidor son diferentes. De las muchas funciones/roles que puede tener el servidor, el DC es fundamental ya que las cuentas de estos servidores no están en unidades organizativas de menor nivel que el de las unidades organizativas del servidor miembro. En su lugar, se ubicarán en el contenedor de **controlador de dominio.** Por este motivo, se crea una política incremental específica para el DC, que implementa el modelo ***CCN-STIC-570A23 Incremental DC (Estandar/uso oficial/Materias clasificadas).inf***

GPO Dominio de directorio activo

Las directivas de cuenta relacionadas a continuación se aplican a cada una de las cuentas de usuarios, servicios y administradores pertenecientes a un dominio.

Directiva de contraseñas

Una contraseña segura que se cambia con frecuencia reduce las posibilidades de un ataque exitoso. La configuración de la **política de contraseñas** controla la **solidez** y la **vigencia** de esta. Esta sección describe la configuración específica para la política de contraseñas. Estas directrices también deben usarse para las contraseñas de todas las cuentas de servicio de la organización. Las políticas de contraseña definidas en la política de dominio afectan las cuentas de usuario en ese dominio Active Directory. Estos parámetros se pueden encontrar en el complemento **Plantillas de seguridad** en: ***a) Directiva de cuenta\Directiva de contraseñas.***

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

La creación de requisitos estrictos de longitud y complejidad de la contraseña no significa necesariamente que esta sea segura para los usuarios y administradores. La habilitación de políticas de contraseñas permite a los usuarios del sistema cumplir con los requisitos de complejidad técnica para estas definidas por el sistema, pero los malos hábitos requieren **políticas de seguridad adicionales.** Por ejemplo, «Cualquiera01» puede cumplir con los criterios de dificultad de la contraseña, pero no es demasiado complicado de determinar.

Según el Centro Criptológico Nacional en STIC 570A (2018) cada organización debe establecer pautas de seguridad para crear contraseñas adecuadas, como:

> «a) Evitar el uso de palabras que figuren en un diccionario, palabras con faltas de ortografía comunes o juegos de palabras y palabras extranjeras.
> b) Evitar utilizar contraseñas a las que se le añade un dígito simplemente.
> c) Evitar utilizar contraseñas que otros puedan adivinar fácilmente viendo su escritorio o bien por ingeniería social (como los nombres de sus mascotas, equipos deportivos y familiares).
> d) Evitar pensar en las contraseñas como palabras propiamente dichas, hay que pensar en códigos secretos.
> e) Deben emplearse contraseñas que requieran escribir con ambas manos en el teclado.
> f) Deben usarse letras mayúsculas y minúsculas, números y símbolos en todas las contraseñas.
> g) Deben usarse espacios y caracteres que solo se pueden producir utilizando la tecla "Alt"» (p. 21).

Adicionalmente a la política de contraseñas anterior, se puede requerir una gestión centralizada de todos los usuarios. Para impedir que un usuario cambie su contraseña, excepto cuando se le solicite, el usuario puede renovarlas dentro de los intervalos mínimos y máximos de contraseñas. No obstante, para diseñar un entorno altamente seguro solo necesita cambiarla si el sistema operativo le notifica después de unos días, según lo determinado por el campo Duración Máxima de la contraseña.

© Universidad Internacional de La Rioja (UNIR)

También, se puede deshabilitar la opción Cambiar contraseña mediante las opciones que aparecen cuando presionan las teclas CTR-ALT-SUPR. Es posible aplicar esta configuración en un dominio completamente mediante la directiva de grupo o editando el registro de cualquier usuario específicamente. Se describe también cómo utilizar la función de **Política de contraseña específica** (FGPP) para configurar diferentes políticas de contraseña según el tipo de usuario o función/rol.

Directiva de bloqueo de cuentas

La política de bloqueo de cuenta controla que, después de varios intentos fallidos de autenticación durante un tiempo determinado, se bloquee la cuenta de un usuario. El usuario no podrá volver a intentar iniciar sesión con una cuenta en estado bloqueada. Para paliar este tipo de ataque se puede desactivar la cuenta después de varios intentos de autenticación fallidos. Estas configuraciones de directivas de bloqueo pueden evitar que los atacantes adivinen contraseñas y reducen las posibilidades de ataques exitosos en el dominio. La directiva de bloqueo de cuenta se puede encontrar en el archivo adjunto de la **Plantilla de seguridad** en la siguiente ubicación: ***a) Directiva de cuenta\Directiva de bloqueo de cuenta.***

El establecimiento de una política de bloqueo de **cuenta restrictiva** mejora la seguridad del dominio, pero además puede aumentar la carga administrativa relacionada con el desbloqueo de cuentas de usuario. Debe tenerse en cuenta que la política de bloqueo de cuentas podría evitar que un atacante que conozca el nombre de la cuenta realice múltiples inicios de sesión falsos y bloquee el acceso de usuarios legítimos posibilitando ataques de denegación de servicio (DOS-DDOS).

© Universidad Internacional de La Rioja (UNIR)

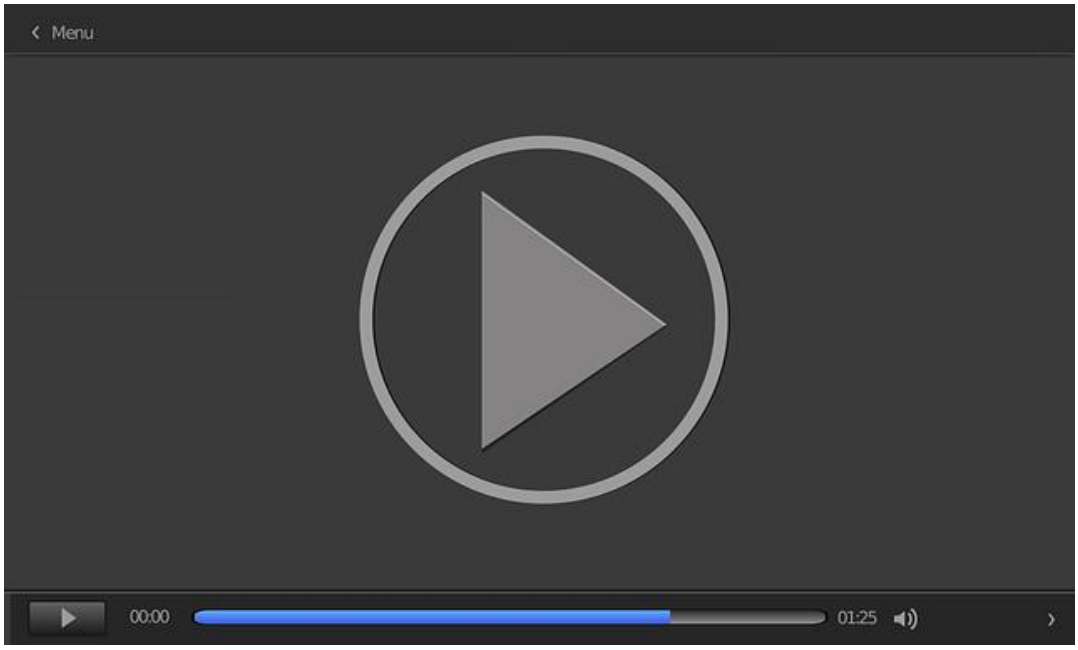
Se debe considerar que la única cuenta que no tiene esta protección es la cuenta de administrador. Deberá cambiar el nombre de esta cuenta para evitar ataques maliciosos. Al igual que con las contraseñas, puede utilizar funciones específicas de política de contraseñas (FGPP) para obtener un mayor control sobre el sistema de bloqueo de su cuenta.

Directiva Kerberos

Las directivas relacionadas con el protocolo Kerberos son necesarias para autenticar y autorizar a los usuarios en el dominio. Dichas políticas definen parámetros relativos a la versión 5 del protocolo Kerberos, como la duración del *ticket* y su cumplimiento. Las directivas del protocolo Kerberos no se configuran en las directivas locales. Al reducir la validez de los *tickets* de Kerberos, se reduce la posibilidad de que un atacante se haga con una contraseña y pueda suplantar una cuenta de usuario legítima. Se recomienda no cambiar los valores predeterminados de estos criterios aunque pueden ser más restrictivos. Estos parámetros se establecen en el complemento Plantilla de seguridad en la siguiente ubicación: ***a) Directivas de cuenta\Directiva Kerberos.***

En el vídeo *Protocolo Kerberos* presentaremos el protocolo de autenticación Kerberos, que se utiliza normalmente en entornos de *Windows Active Directory*.

© Universidad Internacional de La Rioja (UNIR)



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=b3af7b11-c234-47ec-a88a-adbf00c7c56d

En cuanto a los directivos locales, se encuentran los siguientes.

Opciones de seguridad

Algunas directivas correspondientes a las opciones de seguridad también actúan como políticas y directivas de cuenta y se deben considerar a nivel dominio para que se apliquen y añadan protecciones adicionales a las cuentas del dominio.

Estos parámetros se configuran dentro del complemento **Plantillas de Seguridad** en la siguiente ubicación: ***a) Directivas locales\Opciones de seguridad.***

© Universidad Internacional de La Rioja (UNIR)

Las siguientes directivas requieren aclaraciones adicionales por su importancia:

- **Acceso de red:** traducción SID/nombre anónima. Al habilitar esta política en el DC, los usuarios que conocen el atributo SID de administrador pueden iniciar sesión en otros equipos que tengan esta política habilitada y usar ese SID conocido para obtener el nombre de administrador. Ese atacante puede usar el nombre obtenido para lanzar un ataque y averiguar la contraseña.

- **Seguridad de red:** relativo a la configuración, habilitación de los tipos de cifrado permitidos para Kerberos.

Por otro lado, tenemos los registros de eventos.

Los eventos del sistema y de la aplicación se registran en el Registro de eventos. Los registros de seguridad registran y archivan los eventos de auditoría. El contenedor Registro de eventos del modelo-plantilla de seguridad define las propiedades relacionadas con los registros de eventos del sistema, aplicaciones y seguridad, como el tamaño del registro, la firma máxima, los derechos de usuario, el acceso a cada registro, la configuración y los métodos de guardado, etc.

La configuración del registro de eventos relativos al sistema, seguridad y aplicaciones se configura en la política básica para aplicarse a todos los miembros del dominio. Luego, hay que crear políticas específicas para diferentes roles de servidor dentro de cada unidad organizativa. El conjunto de parámetros relativos al registro de eventos mediante el complemento Plantillas de seguridad residen en: ***a) Registro de eventos***.

© Universidad Internacional de La Rioja (UNIR)

GPO Controlador de dominio y servidores miembros

Los DC, junto con los servicios DNS, son clave para proporcionar funcionalidad a la infraestructura de Active Directory. La seguridad de una organización depende en gran medida de estos. Por lo tanto, se requiere establecer un alto nivel de seguridad para estos roles. Esta sección contiene la configuración de seguridad requerida para su DC. Un determinado dominio puede contener distintos servidores que actúan como controladores de dominio. La mayor parte de las configuraciones de esta sección debe crearse solo una vez, con independencia del número de controladores de dominio que hubiese.

Dada la importancia de los datos almacenados, los controladores de dominio siempre deben almacenar esos datos en una ubicación físicamente segura a la que solo puedan acceder los administradores calificados. La función de DC no debe combinarse con otros servicios que una organización pueda proporcionar, a menos que sea absolutamente necesario, como cuando la infraestructura tiene un solo servidor. Asimismo, esta sección también describe los requisitos para los servidores miembros que también requieren seguridad porque no son controladores de dominio pero desempeñan un papel diferente dentro de la organización.

Plantilla de seguridad

Los criterios definidos anteriormente establecen parámetros comunes que deben aplicarse en todo el dominio. Sin embargo, se recomienda que se establezca una **configuración específica** en el **nivel de función/rol** de cada sistema. Esta sección define configuraciones de seguridad adicionales para controladores de dominio y servidores miembro que ejecutan Windows Server. Para los controladores de dominio se debe definir un nuevo patrón incremental específico para que no cambie el GPO predeterminado. Política de DC predeterminada proporcionada por Microsoft. Sin embargo, el nuevo GPO tiene prioridad sobre el GPO establecido por Microsoft como DC predeterminado, ya que consta de varios pasos.

© Universidad Internacional de La Rioja (UNIR)

Estas configuraciones asumen que el dominio está configurado como se describe en la sección de Active Directory. El equipo servidor miembro especificado tiene un GPO adicional, además del GPO aplicado al dominio, que le permite establecer la seguridad en el equipo y el DC.

Directivas de cuenta

Las políticas de cuenta relacionadas con las cuentas de dominio ya están definidas a nivel de dominio, por lo que no es requerido definir adicionalmente ninguna configuración en este conjunto de políticas a menos que se requiera una configuración adicional.

Directivas locales

- **Directivas de auditoría.** Las políticas de auditoría definen los eventos de seguridad que se generan para monitorizar y registrar la actividad de los usuarios o del sistema. Los administradores pueden monitorear las actividades relacionadas con la seguridad, como quién está accediendo al objeto, si el usuario está conectado o desconectado de la computadora y si se han cambiado las configuraciones de auditoría. Los valores de la política de auditoría se pueden encontrar en el archivo adjunto de la plantilla de seguridad en: ***a) Directivas locales\Directiva de auditoría***

- **Asignación de privilegios de usuario.** Es necesario gestionar con el Principio de mínimos privilegios los permisos de cada usuario o grupo en función de la necesidad que tengan de conocer de los recursos del dominio distribuidos en diferentes servidores. Se otorgan permisos para realizar acciones específicas, como iniciar una red o sesión local, y para tareas administrativas, como generar un nuevo *token* de acceso. Los permisos de usuario se establecen en el complemento Plantillas de seguridad en: ***a) Directivas locales\Asignación de derechos de usuario.***

© Universidad Internacional de La Rioja (UNIR)

Algunos parámetros para configurar según la guía STIC 570A (2018) son:

> «a) Denegar el acceso a este equipo desde la red.
>
> b) Denegar el inicio de sesión a través de Servicios de Escritorio remoto.
>
> c) Habilitar confianza con el equipo y las cuentas de usuario para delegación.
>
> d) Tener acceso a este equipo desde la red» (p. 26).

Opciones de seguridad. Como indica STIC 570A (2018), permiten configurar entre otros:

> «a) Cuentas: Configuraciones adicionales a las directivas de cuenta.
>
> b) Auditoría: Configuraciones adicionales a las directivas de auditoría.
>
> c)DCOM: Configuraciones para el modelo de objetos de componentes distribuidos.
>
> d) Dispositivos: Configuraciones para la conexión y desconexión de dispositivos en el equipo, así como acciones realizadas sobre los mismos.
>
> e) Controlador de dominio: Configuraciones específicas para los controladores de dominio.
>
> f) Miembro de dominio: Configuraciones para equipos pertenecientes a un dominio.
>
> g) Inicio de sesión: Configuraciones para definir acciones sobre el inicio de sesión en los equipos.
>
> h) Cliente de red Microsoft: Configuraciones para establecer las comunicaciones entre equipos clientes.
>
> i) Servidor de red Microsoft: Configuraciones para establecer las comunicaciones entre equipos servidores.
>
> j) Acceso a la red: Configuraciones para definir acciones sobre los accesos a la red.
>
> k) Seguridad de red: Configuraciones sobre aspectos de protocolos en red.
>
> l) Consola de recuperación: Configuraciones para determinar acciones a poder realizar sobre la consola de recuperación.
>
> m) Apagar: Configuraciones para definir el apagado del equipo.
>
> n) Criptografía: Configuraciones acerca de algoritmos a utilizar.
>
> o) Objetos del sistema: Configuración para distinción de mayúsculas y minúsculas, así como el refuerzo sobre los permisos de objetos de Windows.
>
> p) Configuración del sistema: Configuración para compatibilidades y procesamiento de certificados.
>
> q) Control de cuentas de usuario: Configuraciones para establecer el comportamiento de la UAC.» (p. 27).

© Universidad Internacional de La Rioja (UNIR)

Como se mencionó anteriormente, es necesario definir una política de grupo que tenga mayor nivel de prioridad sobre la política configurada de forma predeterminada. Estas directivas deben ser siempre más restrictivas para no afectar la seguridad establecida por la política predeterminada. Las opciones de seguridad se definen en el complemento Plantilla de seguridad en: ***a) Directivas locales\Opciones de seguridad.***

Servicios del sistema

En Windows Server se encuentran disponibles servicios opcionales adicionales, como el denominado **«Servicio de certificados de Active Directory».** Este servicio no viene en la instalación predeterminada de Windows Server. Puede agregar servicios a su sistema activando manualmente cualquier roles o característica que se considere necesaria. Se puede usar la **Consola de Administración** del servidor o **cmdlets de PowerShell** para automatizar. Todos los servicios o aplicaciones son puntos potenciales de ataque.

Es importante que los servicios o ejecutables no deseados se desactiven o eliminen. El modelo de seguridad asociado con estas directrices tiene esto en cuenta y deshabilita así los servicios que no se consideran necesarios para el funcionamiento normal. Si se necesita habilitar servicios deshabilitados a través del GPO, en este tutorial en algunos DC o servidores miembro se debe cambiar el modelo incremental de controladores de dominio o servidores miembro. Sin embargo, hay que evaluar el impacto de habilitar un servicio y asegurarse de que estará siempre actualizado. Tener en cuenta que Microsoft puede agregar nuevos servicios que deben configurarse correctamente.

Este tutorial asume que los roles Active Directory y Servidor DNS están activos en el servidor del DC, ya que este último generalmente está asociado con el primero. La configuración del servicio del sistema se puede cambiar utilizando el complemento Plantillas de seguridad en: ***a) Servicios del sistema.***

© Universidad Internacional de La Rioja (UNIR)

Registro

El modelo-plantilla de seguridad posibilita aplicar **permisos más restrictivos** al registro del servidor. Generalmente, la seguridad predeterminada del registro de Windows Server es suficiente, incluso si se requieren cambios. Los permisos de registro se pueden configurar mediante el complemento Plantillas de seguridad en la siguiente ubicación: ***a) Registro.***

Otras recomendaciones de seguridad

Algunas configuraciones adicionales no se pueden implementar en esta sección utilizando los modelos de seguridad descritos. Algunos de ellos no se implementan de acuerdo con las instrucciones del tutorial, pero se describen aquí en caso de que el administrador decida ejecutarlos.

Firewall de Windows con seguridad avanzada

Windows Server incluye un firewall nativo que posibilita definir **reglas de filtro** para permitir o denegar el **tráfico de red** hacia y desde el servidor. Esta función de firewall se denomina «Firewall de Windows con seguridad avanzada» y se configura en la consola de administración de Server Administrator mediante netsh (netsh advfirewall) desde la línea de comandos. También se puede configurar mediante un objeto de directiva de grupo (Configuración del equipo-Directivas-Configuración de Windows-Configuración de seguridad-Firewall de Windows con seguridad avanzada). Una descripción precisa de todas las opciones de configuración de seguridad avanzadas está fuera del alcance de este documento.

© Universidad Internacional de La Rioja (UNIR)

Como se encuentra en el manual STIC 570A (2018), **las reglas y políticas de firewall se agrupan en tres perfiles**, por lo que para cada conexión de red solo se aplica la que coincide con uno de los perfiles en un momento dado:

> «a) Dominio: Se aplica cuando el servidor tiene conectividad con un controlador de dominio a través de esa interfaz de red.
> b) Privado: Se aplica cuando el servidor no tiene conectividad con un controlador de dominio y la red a la que está conectado ha sido categorizada como privada por el administrador.
> c) Público: Se aplica cuando el servidor no tiene conectividad con un controlador de dominio y la red a la que está conectado no ha sido categorizada por el administrador, o ha sido categorizada como red pública» (p. 36).

Cada perfil define una política predeterminada que se colocará a los paquetes de red que se apliquen al perfil si dichos paquetes no tienen reglas de filtrado específicas. Se pueden especificar diferentes opciones para conexiones entrantes y salientes. Le recomendamos que **utilice la siguiente configuración para todos los perfiles** según indica STIC 570A (2018):

> «a) Conexiones entrantes: Bloquear las conexiones entrantes que no coincidan con una regla.
> b) Conexiones salientes: Permitir las conexiones salientes que no coincidan con una regla» (p. 35).

En esta configuración, debe permitir todas las conexiones de red al servidor y definir reglas de filtrado para las conexiones entrantes dirigidas a los servicios que deben ser realmente accesibles en la red. Por ejemplo, para permitir que los clientes realicen consultas de DNS en el servidor las reglas de firewall deben permitir conexiones entrantes directas al puerto 53 / UDP si el servidor desempeña esta función.

© Universidad Internacional de La Rioja (UNIR)

Windows Server incluye un conjunto de reglas de forma predeterminada cuando se instala sin una función o característica. La instalación real de la función o función incluye la creación automática de las reglas necesarias para esta función o los servicios de red proporcionados por estas funciones.

En general, estas reglas generadas automáticamente son muy seguras, pero debe verificarlas y deshabilitar las innecesarias. Por ejemplo, si su servidor no tiene IPv6 habilitado, puede deshabilitar todas las reglas de firewall que permiten el tráfico IPv6. Si no está utilizando DHCP, puede deshabilitar cualquier regla que permita el tráfico DHCP. Las instrucciones paso a paso del CCNSTIC570A23, anexo A (Centro Cripológico Nacional, 2023), que incluyen la configuración del modelo-plantilla de seguridad, muestran la configuración recomendada para el Firewall de Windows con seguridad mejorada para los controladores de dominio y los servidores miembro en cada entorno.

Estas **configuraciones de firewall** recomendadas se incluyen como una directiva de firewall (archivo con la extensión «.wfw») que puede importar a su computadora o a un objeto GPO. Las instrucciones (CCNSTIC570A23 anexo A) cubren los pasos necesarios para aplicarlas a través del GPO.

Desactivación de protocolos innecesarios

Con el objetivo de reducir aún más la superficie de ataque se deben deshabilitar todos aquellos protocolos de red que no sean estrictamente necesarios.

© Universidad Internacional de La Rioja (UNIR)

Cuentas de servicio

No configurar un servicio para que se ejecute en el contexto de seguridad de cualquier cuenta de dominio a menos que sea necesario de forma imprescindible. Si su servidor está físicamente comprometido, puede obtener fácilmente la contraseña de su cuenta de dominio obteniendo el secreto de la **Autoridad de seguridad local (LSA).** Si necesita iniciar el servicio con una cuenta de dominio, le recomendamos que utilice la cuenta de servicio administrada que se vio con anterioridad.

GPO Seguridad Clientes Windows miembro de dominio

Para mejorar la seguridad de los clientes con sistema operativo Windows 10 en un dominio se recomienda aplicar el anexo de la guía CCN-STIC-599A23 ENS incrementa clientes categoría básica. Aplicada a las correspondientes OU que albergan los clientes de la organización, se pueden configurar de forma específica medidas relativas al control de acceso (identificación, requisitos de acceso, mecanismos de autenticación, etc.), registro de la actividad de los usuarios, asignación de derechos de usuario, opciones de seguridad de control de cuentas de usuario, etc.

© Universidad Internacional de La Rioja (UNIR)

1.4. Analizadores de políticas base

El Security Compliance Toolkit (SCT), dice Montemayor (2021), «es un conjunto de herramientas que permite a los administradores de seguridad empresarial descargar, analizar, probar, editar y almacenar las líneas base de configuración de seguridad recomendadas por Microsoft para Windows y otros productos de Microsoft. SCT permite a los administradores administrar eficazmente los objetos de directiva de grupo (GPO)».

Los administradores utilizan el kit de herramientas para comparar con los GPO actuales de Microsoft u otras líneas base recomendadas, modificarlos, guardarlos en el formato de archivo de copia de seguridad de GPO y aplicarlos juntos mediante Active Directory o se pueden aplicar individualmente mediante directivas locales.

Policy Analyzer es una utilidad para analizar y comparar colecciones de objetos de directiva de grupo (GPO). Sus principales características según Dansimp (2021), son:

> «-Resaltar cuando un conjunto de directivas de grupo tiene una configuración redundante o incoherencias internas.
> -Resaltar las diferencias entre las versiones o los conjuntos de directivas de grupo.
> -Comparar los GPO con la directiva local actual y la configuración del registro local.
> -Exportar los resultados a una hoja de cálculo de Microsoft Excel».

El analizador de políticas le permite tratar un conjunto de GPO como una sola unidad. Esto facilita la determinación de si ciertos valores se repiten en el GPO o si se definen como valores en conflicto. También puede utilizar el analizador de políticas para capturar una línea de base y compararla con una instantánea que tome más tarde para identificar cambios en cualquier parte del conjunto.

© Universidad Internacional de La Rioja (UNIR)

1.5. Herramientas de análisis de configuración de seguridad

Herramienta para evaluar las características de seguridad técnicas definidas a través del Real Decreto 3/2010, actualizado por el Real Decreto 311/2022 por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica. El análisis de cumplimiento se basa en las normas proporcionadas por las plantillas de seguridad de las guías específicas de las series 500, 600 y 800.

Hay que tener en cuenta que las áreas de aplicación de este tipo de modelos son tan diferentes que la especificidad y funcionalidad de los servicios que ofrecen las distintas organizaciones depende de su aplicación. Como resultado, se han creado modelos y estándares de seguridad para definir principios generales de seguridad para el cumplimiento de los valores mínimos establecidos en ENS.

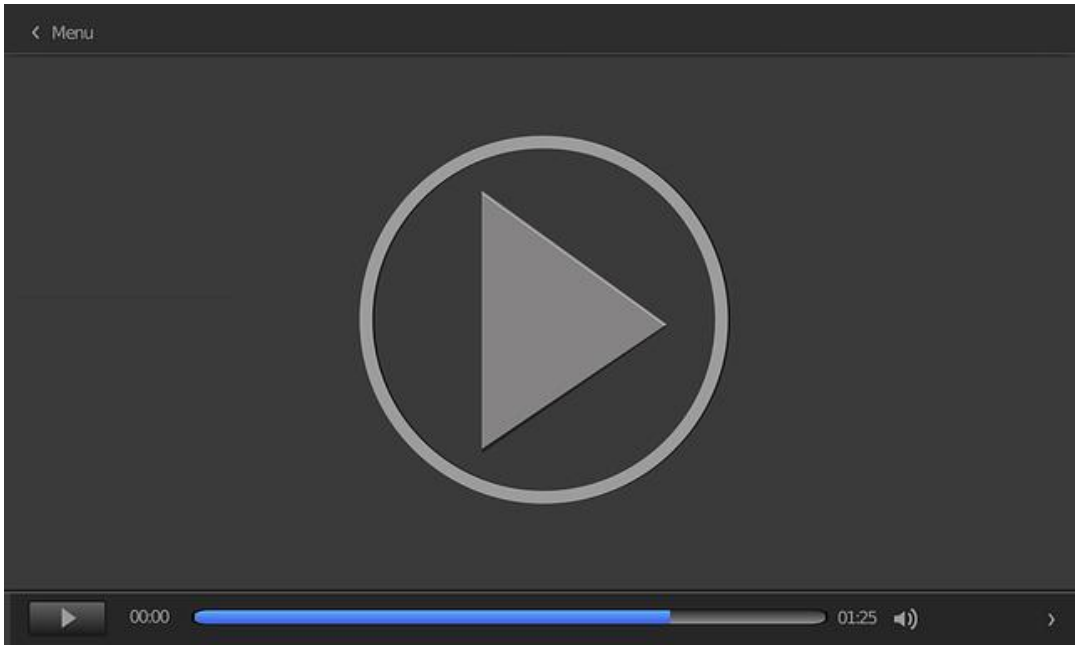
Sin embargo, algunas organizaciones deben tener en cuenta que las plantillas definidas pueden haber sido modificadas para adaptarse a sus necesidades operativas.

Esta aplicación incluye CLARA ENS (64 bits) para análisis independientes en un entorno Microsoft Windows y CLARA ENS-LINUX para un entorno Linux. La herramienta de escaneo de cumplimiento funciona solo en sistemas Windows y Linux, independientemente de las versiones de cliente y servidor, miembros de dominio o dominios.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

En el vídeo *Herramientas de seguridad Windows Server* se verán varias de las herramientas disponibles para analizar las políticas base y las configuraciones de seguridad de un dominio Windows Active Directory.



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=6f8ddfbe-fc53-460f-a27c-adbf00b24f7b

© Universidad Internacional de La Rioja (UNIR)

1.6. Referencias bibliográficas

Centro Criptológico Nacional. (2022). Clara. *CCN-CERT.* https://www.ccn-cert.cni.es/soluciones-seguridad/clara.html

Centro Criptológico Nacional. (2018). *Guía de Seguridad de las TIC. Implementación de seguridad sobre microsoft windows server 2016 (controlador de dominio o servidor miembro).* Ministerio de defensa. https://www.ccn-cert.cni.es/pdf/guias/series-ccn-stic/guias-de-acceso-publico-ccn-stic/3182-ccn-stic-570a-ens-anexo-a/file.html

Centro Criptológico Nacional. (2023). *Guía de Seguridad de las TIC CCN-STIC 570A23. Perfilado de seguridad para Windows server (controlador de dominio o servidor miembro).* CCN. https://www.ccn-cert.cni.es/es/guias-de-acceso-publico-ccn-stic/7104-ccn-stic-570a23-perfilado-de-seguridad-para-windows-server-controlador-de-dominio-o-servidor-miembro/file.html

Dansimp. (25 de noviembre de 2021). Microsoft Security Compliance Toolkit 1.0: Cómo usar. *Docsmicrosoft.* https://docs.microsoft.com/es-es/windows/security/threat-protection/windows-security-configuration-framework/security-compliance-toolkit-10

Fran. (28 de junio de 2010). Diseño eficaz de unidades organizativas. *Administrador de redes.* http://administrador-redes.blogspot.com/2010/06/diseno-eficaz-de-unidades-organizativas.html

Hartmann, C. (2024). *Overview of Changes and New Security Features in Windows Server 2025.* Mondoo. https://mondoo.com/blog/overview-of-changes-and-new-security-features-in-windows-server-2025

© Universidad Internacional de La Rioja (UNIR)

LaFoute, A. (2025). *Windows Server2025 Features Explained: Security, Hotpatching, SMB over QUIC, GPU-P & Hybrid Cloud Upgrades.* Windows Mode. https://www.windowsmode.com/whats-new-in-windows-server-2025/

Microsoft. (2025). *Discover what's new in Windows Server 2025.* Microsoft. https://cdn-dynmedia-1.microsoft.com/is/content/microsoftcorp/microsoft/final/en-us/microsoft-brand/documents/windows-server-2025-data-sheet.pdf

Montemayor, D. (4 de diciembre del 2021). Microsoft Security Compliance Toolkit 1.0 U s a g e . *DocsMicrosoft.* https://docs.microsoft.com/es-es/windows/security/threat-protection/security-compliance-toolkit-10

Munck, R. (2025). *Windows Server 2025, security baseline.* Tech Community. https://techcommunity.microsoft.com/blog/microsoft-security-baselines/windows-server-2025-security-baseline/4358733

NedPyle. (2024). *SMB security hardening in Windows Server 2025 & Windows 11.* Tech Community. https://techcommunity.microsoft.com/blog/filecab/smb-security-hardening-in-windows-server-2025--windows-11/4226591

Posey, B. (2024). *New Active Directory features coming in Windows Server 2025.* Tech Target. https://www.techtarget.com/searchwindowsserver/tip/New-Active-Directory-features-coming-in-Windows-Server-2025

© Universidad Internacional de La Rioja (UNIR)

Guías de seguridad de entornos Windows 500 CCN-CERT

Centro Criptológico Nacional (13 de enero de 2025). *500 guías de entornos Windows*. https://www.ccn-cert.cni.es/guias/guias-series-ccn-stic/500-guias-de-entornos-windows.html

En este sitio web se pueden encontrar muy diversas guías de configuración de seguridad para entornos Windows.

© Universidad Internacional de La Rioja (UNIR)

Configuraciones de seguridad de entornos Windows NIST

National Institute of Standars and Technology. (2025). *Checklist Repository.* https://ncp.nist.gov/repository?keyword=Microsoft+Windows&startIndex=0

En este sitio web se pueden encontrar muy diversas guías de configuración de seguridad para entornos Windows.

© Universidad Internacional de La Rioja (UNIR)

Herramienta CLARA CCN CERT

Centro Criptológico Nacional (13 de enero de 2022). *CLARA.* https://www.ccn-cert.cni.es/soluciones-seguridad/clara.html

Herramienta para analizar las características de seguridad técnicas definidas a través del Real Decreto 3/2010 por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica. El análisis del cumplimiento está basado en las normas proporcionadas a través de las plantillas de seguridad de las Guías CCN-STIC 850A, 850B, 851B, 870A, 870B, 570A, 570B, 599A18, 599B18, 599A19, 599B19, 619 y 619B.

© Universidad Internacional de La Rioja (UNIR)

Security Compliance Toolkit de Microsoft 1.0

DulceMontemayor. (4 de diciembre de 2021). Microsoft Security Compliance Toolkit 1.0 Usage. *DocsMicrosoft.* https://docs.microsoft.com/es-es/windows/security/threat-protection/security-compliance-toolkit-10

El Security Compliance Toolkit (SCT) es un conjunto de herramientas que permite a los administradores de la seguridad empresarial descargar, analizar, probar, editar y almacenar líneas base de configuración de seguridad recomendadas por Microsoft para Windows y otros productos de Microsoft.

© Universidad Internacional de La Rioja (UNIR)

Configuración de seguridad Active Directory a través de Group Policy Objects

Security Options. (2023). https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-10/security/threat-protection/security-policy-settings/security-options

La configuración de la política de seguridad son reglas que los administradores configuran en un equipo o en varios dispositivos para proteger los recursos de un dispositivo o una red. La extensión Configuración de seguridad del complemento Editor de directivas de grupo local, le permite definir configuraciones de seguridad como parte de un objeto de directiva de grupo (GPO). Los GPO están vinculados a contenedores de Active Directory, como sitios, dominios o unidades organizativas, y le permiten administrar la configuración de seguridad de varios dispositivos desde cualquier dispositivo unido al dominio. Las directivas de configuración de seguridad se utilizan como parte de la implementación de seguridad general para ayudar a proteger los controladores de dominio, servidores, clientes y otros recursos de su organización.

© Universidad Internacional de La Rioja (UNIR)

1. Cada servidor recibirá las configuraciones de seguridad a través de directivas de grupo en el nivel de dominio:

A. Para cumplir los requisitos comunes de seguridad.

B. Para cumplir los requisitos de seguridad específicos del servidor.

C. Para cumplir los requisitos de seguridad de los roles específicos del servidor.

D. Ninguna de las anteriores.

2. Cada servidor recibirá las configuraciones de seguridad a través de directivas de grupo en el nivel de referencia:

A. Para cumplir los requisitos comunes de seguridad.

B. Para cumplir los requisitos de seguridad específicos del servidor.

C. Para cumplir los requisitos de seguridad de los roles específicos del servidor.

D. Ninguna de las anteriores.

3. ¿Cada servidor recibirá las configuraciones de seguridad a través de directivas de grupo en el nivel de rol:

A. Para cumplir los requisitos comunes de seguridad.

B. Para cumplir los requisitos de seguridad específicos del servidor.

C. Para cumplir los requisitos de seguridad de los roles específicos del servidor.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

4. La protección avanzada Seguridad multicapa *core-to-cloud* es una característica de Windows Server:

A. 2025.

B. 2019.

C. 2022.

D. Ninguna de las anteriores.

5. La novedad Credential Guard activado por defecto es una característica de Windows Server introducida en la versión

A. 2019.

B. 2025.

C. 2022.

D. Ninguna de las anteriores.

6. La novedad Secured-core server es una característica de Windows Server introducida en la versión:

A. 2019.

B. 2016.

C. 2022.

D. Ninguna de las anteriores.

7. Las directivas de cuenta afectan a:

A. Solo a las cuentas de usuarios.

B. Solo a las cuentas de servicio.

C. Solo a los administradores.

D. Todas las anteriores son ciertas.

© Universidad Internacional de La Rioja (UNIR)

8. ¿Dónde se especifican los cifrados permitidos para Kerberos?

A. Directivas de cuenta\opciones de seguridad.

B. Directivas locales\opciones de seguridad.

C. Directivas de contraseñas\opciones de seguridad.

D. Ninguna de las anteriores.

9. La directiva de auditoría para un controlador de dominio es una:

A. Directiva local.

B. Directiva de cuenta.

C. Directiva de registro.

D. Ninguna de las anteriores.

10. ¿Qué elemento permite definir reglas de filtrado para definir el tráfico de red entrante y saliente del servidor que debe ser permitido o denegado?

A. *Reverse proxy.*

B. *Firewall.*

C. Opciones de seguridad.

D. Todas las anteriores son ciertas.

© Universidad Internacional de La Rioja (UNIR)